TryHackMe – Lian_Yu

Penetration Testing Walkthrough Report

Prepared by: Manoj Bora
Platform: TryHackMe | Room: Lian_Yu | Difficulty: Medium
Date: 24 September 2026

---

1. Objective

This report covers my walkthrough of the TryHackMe room "Lian_Yu", a boot2root machine based on the Arrow TV series. The goal was to enumerate the target, find a foothold, get user access, capture the user flag, and then escalate privileges to root.

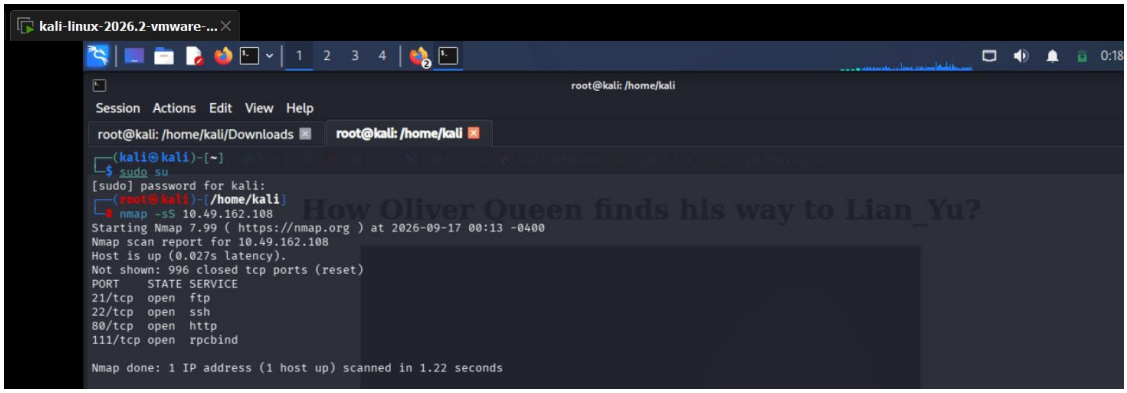
2. Tools Used

- Nmap – port scanning
- Gobuster – directory/file brute-forcing
- Firefox (view-source) – manual web inspection
- Boxentriq – online Base58 decoder
- FTP (CLI client) – file access
- Steghide & StegSeek – steganography extraction/cracking
- Hex editor – raw file inspection and repair
- Wikipedia – file signature reference
- Hydra – SSH credential brute-forcing
- SSH – remote access
- GTFOBins – privilege escalation reference
- pkexec – privilege escalation vector

3. Walkthrough

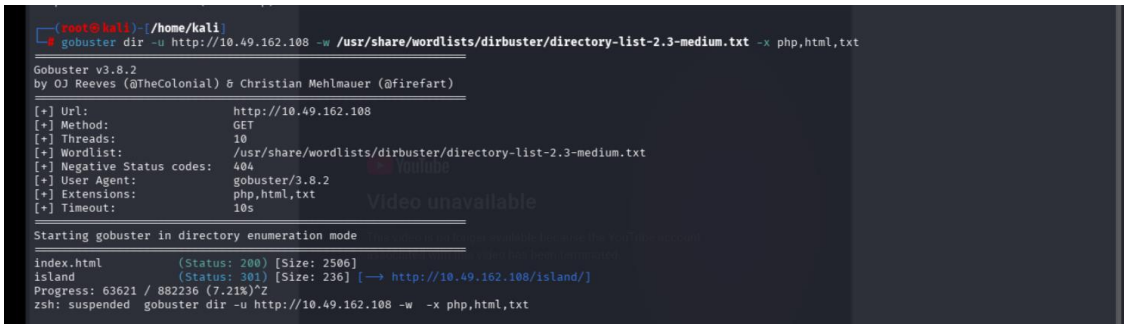
Reconnaissance

1. Started with an Nmap scan against the target IP (nmap -sS <target-ip>). It came back with 4 open ports — 21 (FTP), 22 (SSH), 80 (HTTP) and 111 (rpcbind).

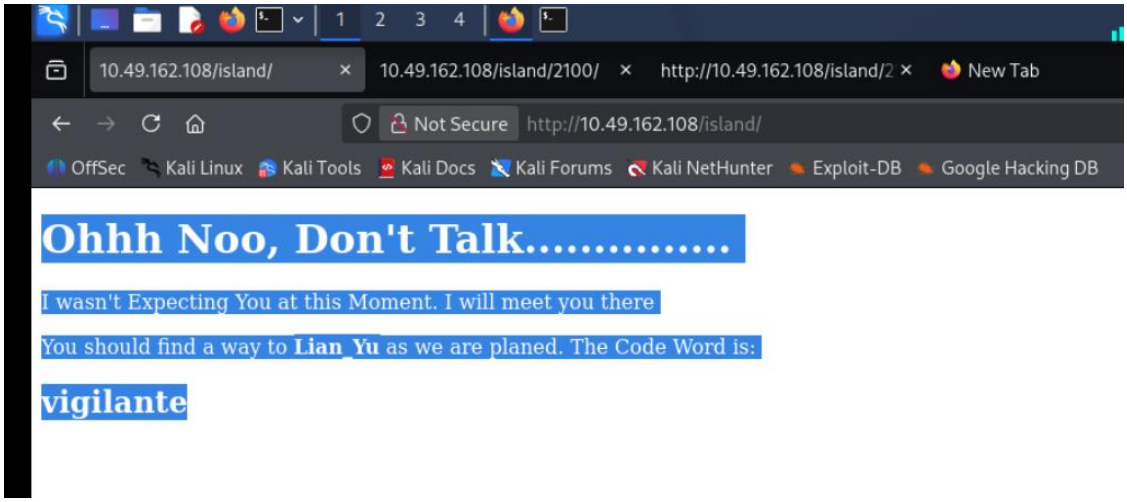


Web Enumeration

2. Since port 80 was open, I ran Gobuster against the web root (gobuster dir -u http://<ip> -w directory-list-2.3-medium.txt -x php,html,txt). It turned up index.html and a directory called island, which redirected (301) to /island/.



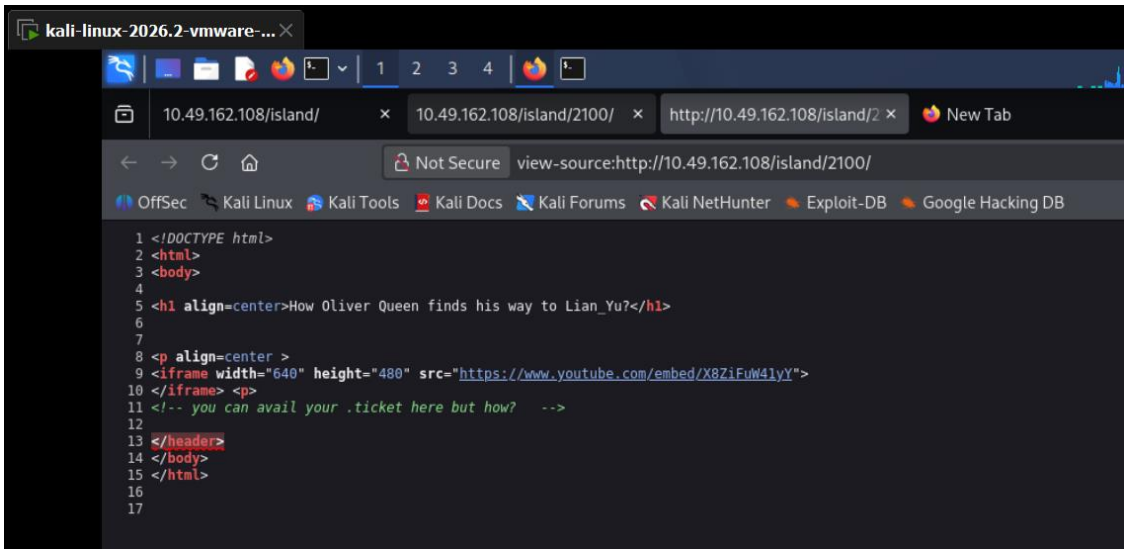
3. Opened /island/ in the browser. The page had a hidden message on it: "You should find a way to Lian_Yu as we are planned. The Code Word is: vigilante." — noted down "vigilante" as the code word.



4. Ran Gobuster again, this time against /island/. It found another index.html and a directory 2100, which redirected to /island/2100/.



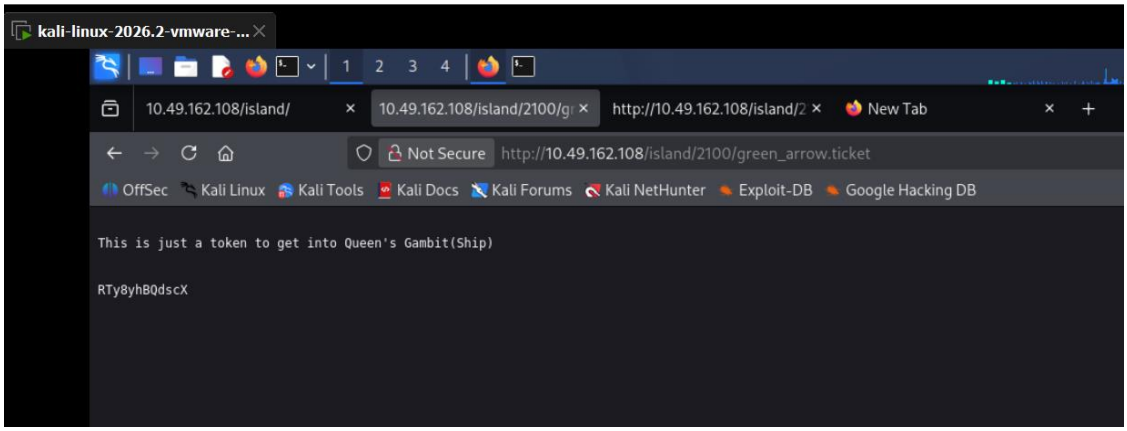
5. Checked the page source of /island/2100/ using view-source. There was an HTML comment hinting: "you can avail your .ticket here but how?" — a clue that a file with a .ticket extension existed.



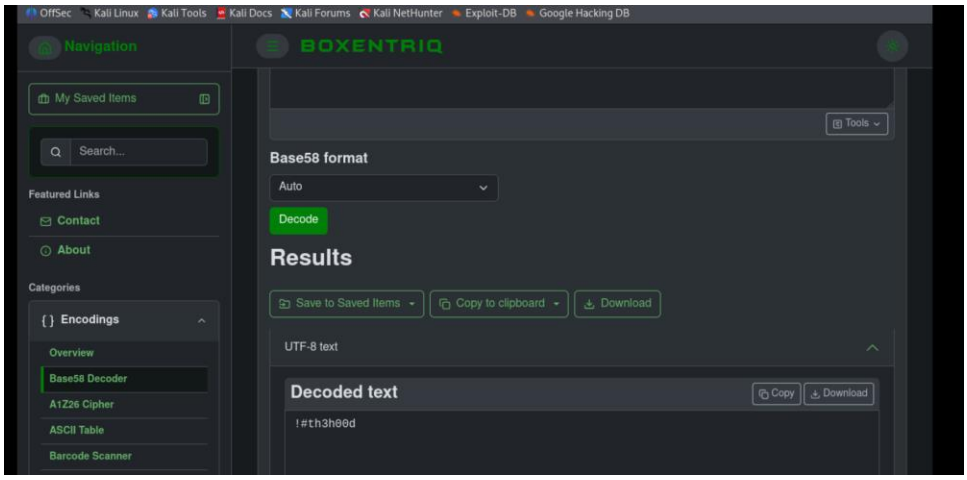
6. Ran Gobuster once more on /island/2100, this time adding .ticket to the search extensions. It found a file called green_arrow.ticket.



7. Opened green_arrow.ticket in the browser. It read: “This is just a token to get into Queen's Gambit (Ship)”, followed by the string RTy8yhBQdscX.

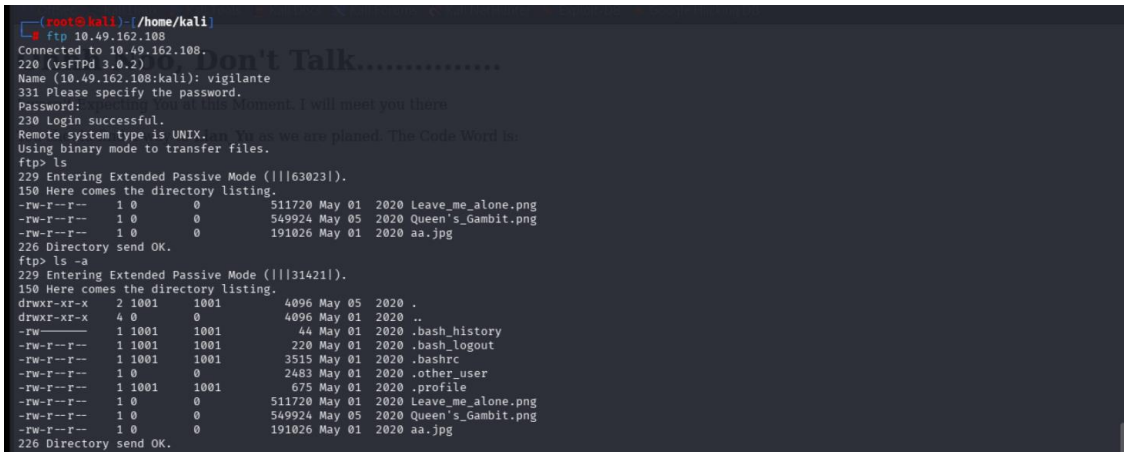


8. Ran that string through Boxentriq's online Base58 decoder. It decoded to !#th3h00d — looked like a password.



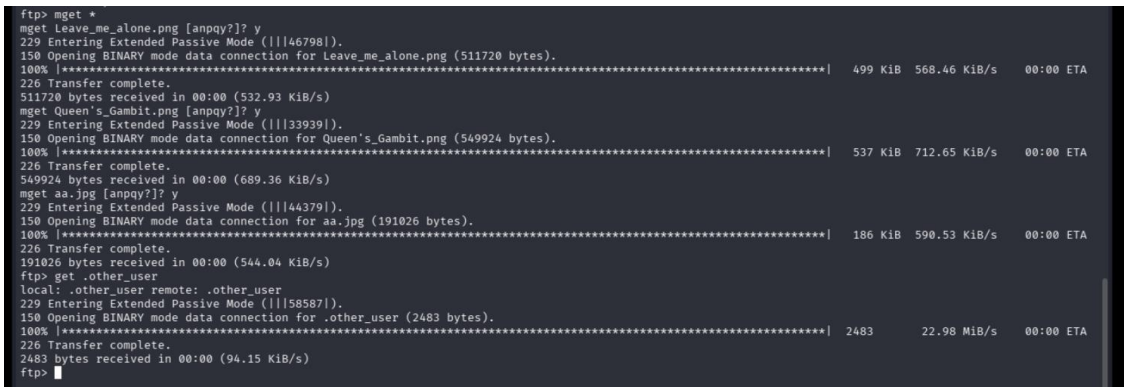
FTP Access & Steganography

9. Connected to FTP using the code word “vigilante” as the username and the decoded string as the password — login succeeded. Listing the directory (ls and ls -a) showed three visible files (Leave_me_alone.png, Queen's_Gambit.png, aa.jpg) and a hidden file, .other_user.



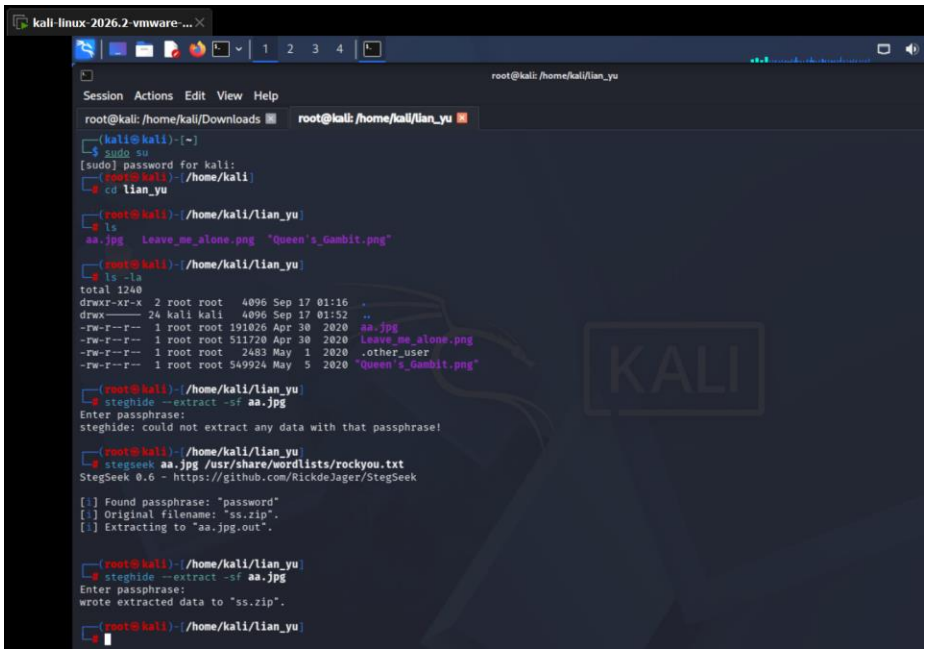
```
┌──(root㉿kali)-[/home/kali]
└─# ftp 10.49.162.108
Connected to 10.49.162.108.
220 (vsFTPd 3.0.2)
Name (10.49.162.108:kali): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||63023|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp> ls -a
229 Entering Extended Passive Mode (|||31421|).
150 Here comes the directory listing.
drwxr-xr-x    2 1001     1001         4096 May 05  2020 .
drwxr-xr-x    4 0        0            4096 May 01  2020 ..
-rw-------    1 1001     1001           44 May 01  2020 .bash_history
-rw-r--r--    1 1001     1001          220 May 01  2020 .bash_logout
-rw-r--r--    1 1001     1001         3515 May 01  2020 .bashrc
-rw-r--r--    1 0        0            2483 May 01  2020 .other_user
-rw-r--r--    1 1001     1001          675 May 01  2020 .profile
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
```

10. Downloaded everything with mget *, then separately pulled down the hidden .other_user file with get.

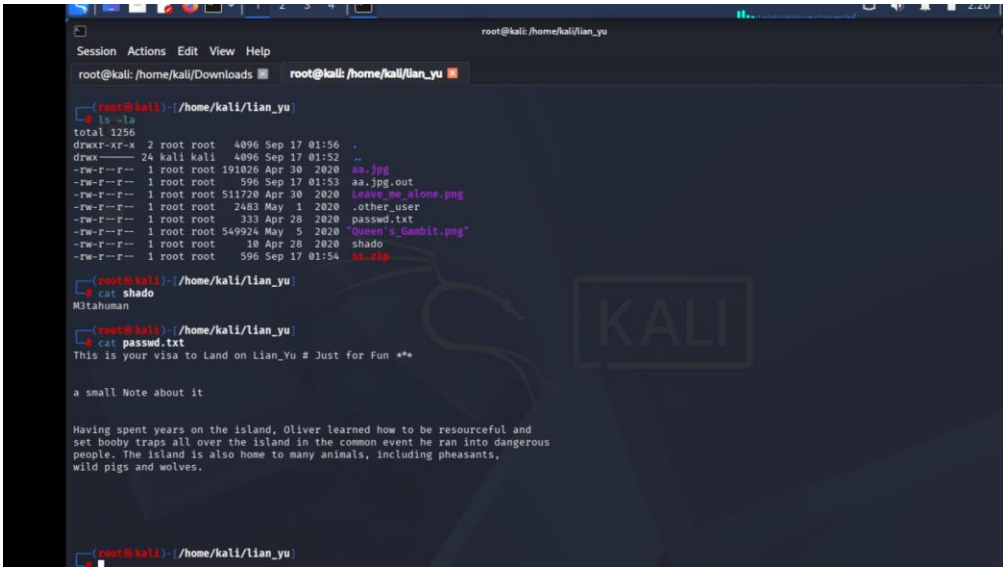


```
ftp> mget *
mget Leave_me_alone.png [anpqy?]? y
229 Entering Extended Passive Mode (|||46798|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
100% |***********************************************************************************************************************|   499 KiB  568.46 KiB/s    00:00 ETA
226 Transfer complete.
511720 bytes received in 00:00 (532.93 KiB/s)
mget Queen's_Gambit.png [anpqy?]? y
229 Entering Extended Passive Mode (|||33939|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
100% |***********************************************************************************************************************|   537 KiB  712.65 KiB/s    00:00 ETA
226 Transfer complete.
549924 bytes received in 00:00 (689.36 KiB/s)
mget aa.jpg [anpqy?]? y
229 Entering Extended Passive Mode (|||44379|).
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
100% |***********************************************************************************************************************|   186 KiB  590.53 KiB/s    00:00 ETA
226 Transfer complete.
191026 bytes received in 00:00 (544.04 KiB/s)
ftp> get .other_user
local: .other_user remote: .other_user
229 Entering Extended Passive Mode (|||58587|).
150 Opening BINARY mode data connection for .other_user (2483 bytes).
100% |***********************************************************************************************************************|  2483       22.98 MiB/s    00:00 ETA
226 Transfer complete.
2483 bytes received in 00:00 (94.15 KiB/s)
ftp>
```

11. Tried steghide --extract on aa.jpg, but it failed without the right passphrase. Ran StegSeek against aa.jpg with the rockyou.txt wordlist, and it cracked the passphrase — “password” — revealing a hidden file called ss.zip. Re-ran steghide --extract with that passphrase to pull ss.zip out for real.

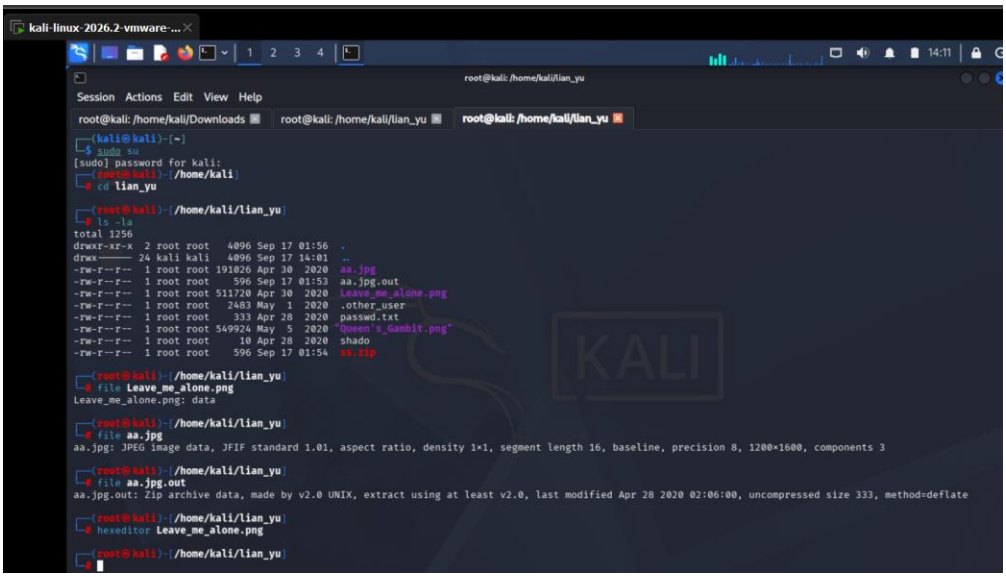


12. Unzipped ss.zip and looked inside — found a file called shado containing the string M3tahuman, and a passwd.txt note (mostly flavour text about Oliver Queen's traps and the island's wildlife).

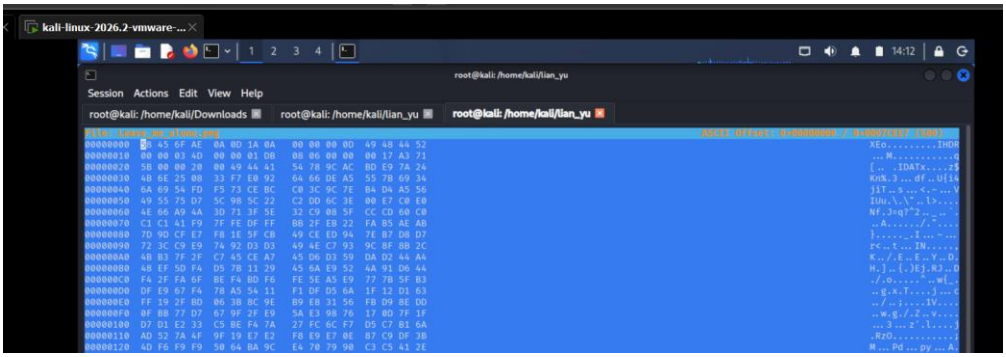


Fixing the Corrupted PNG

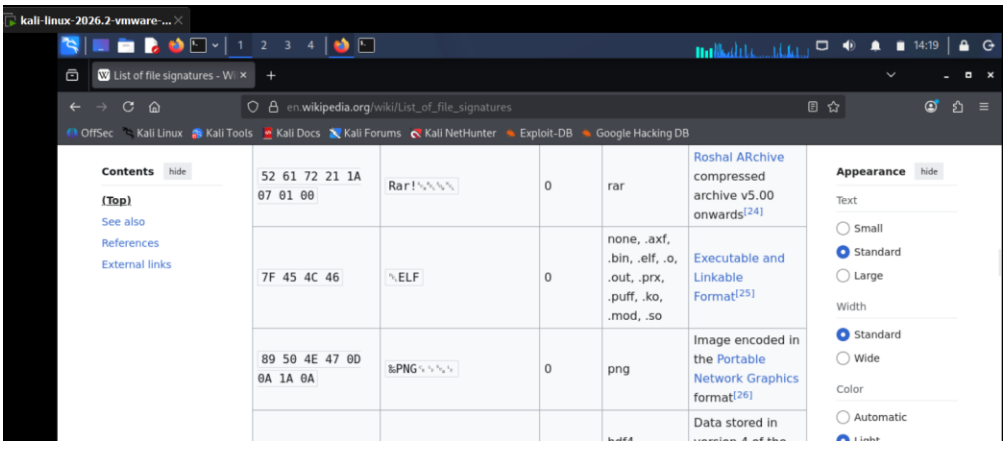
13. Ran file against the downloaded images. Leave_me_alone.png came back as plain “data” instead of a valid PNG — a sign the file header had been tampered with. aa.jpg was a normal JPEG, and aa.jpg.out turned out to be a ZIP archive. Opened Leave_me_alone.png in a hex editor to look at the raw bytes.



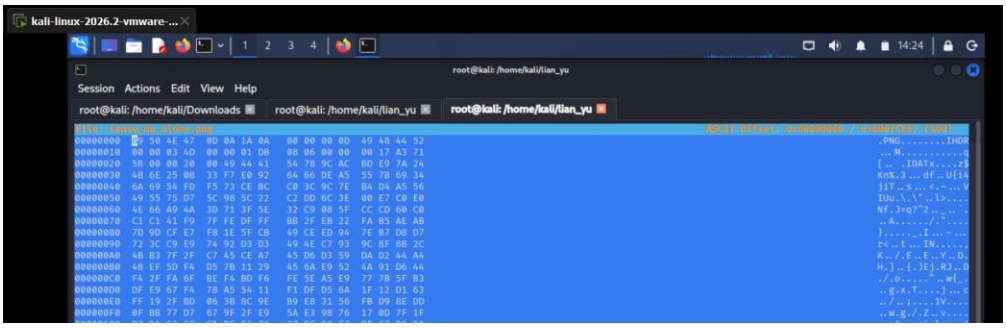
14. In the hex editor, the first bytes read 58 45 6F AE… — not the standard PNG signature, confirming the header had been deliberately altered.



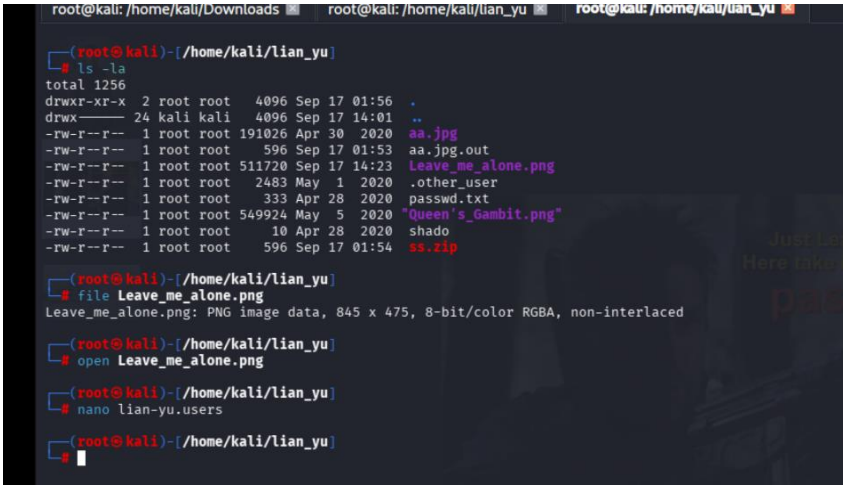
15. Checked Wikipedia's "List of file signatures" page to confirm the correct PNG magic bytes: 89 50 4E 47 0D 0A 1A 0A.



16. Went back into the hex editor and corrected the first bytes of Leave_me_alone.png to match the proper PNG signature.

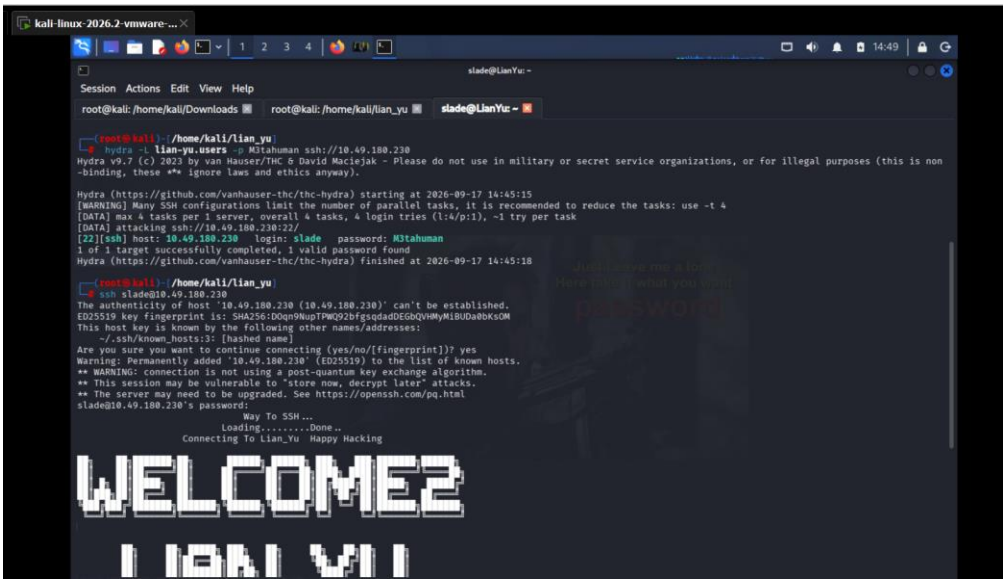


17. With the header fixed, file now identified it as a valid PNG (845×475). Opened the image and found it contained a list of usernames, which I saved into a text file, lian-yu.users.



Gaining Access (SSH)

18. Used Hydra to brute-force SSH logins with the username list and the password found earlier (hydra -L lian-yu.users -p M3tahuman ssh://<ip>). It returned a valid pair — username slade, password M3tahuman. Logged in over SSH as slade and landed on a "WELCOME2 LIAN_YU" banner.

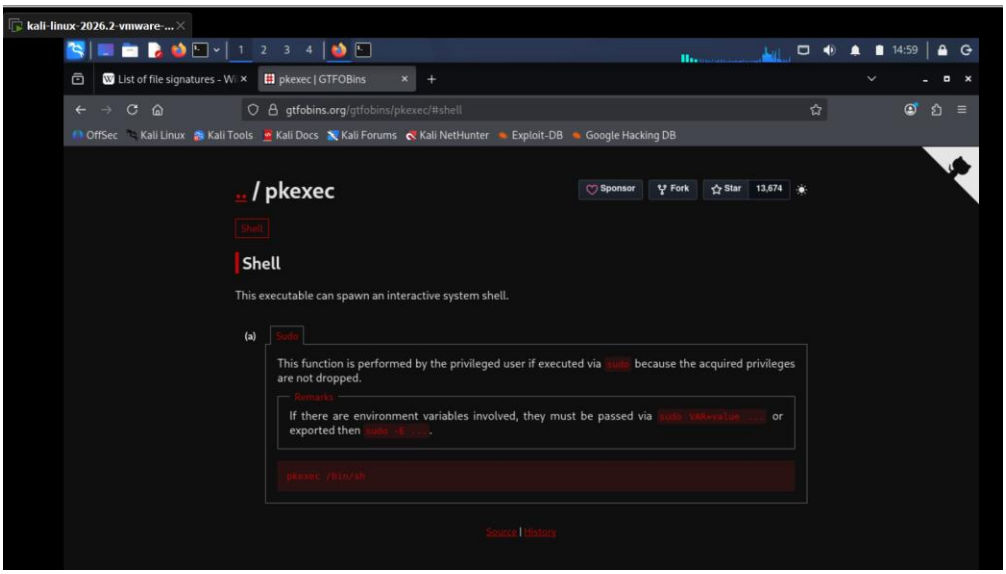


19. Looked around the home directory and found user.txt. Reading it gave the user flag, signed "Felicity Smoak". Checked sudo permissions with sudo -l and found slade was allowed to run /usr/bin/pkexec as root.



Privilege Escalation

20. Looked up pkexec on GTFOBins, which confirmed the binary can be abused with sudo to spawn a full root shell.



21. Ran sudo /usr/bin/pkexec /bin/bash, which dropped straight into a root shell. Listed the directory, found root.txt, and read it — "Mission accomplished", along with the root flag signed "Deathstroke".



4. Flags Captured

User Flag: THM{P30P7E_K33P_53CRET5__COMPUT3R5_D0N'T}

Root Flag:
`THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}`

5. Findings & Vulnerabilities

Summary of the weaknesses that made this box solvable, rated by how much impact they had on the compromise:

Finding	Severity
Hidden directories and HTML comments on the web server leaked hints (code word, ticket path) with no access control	**Low**
Sensitive token was only Base58-encoded, not encrypted — trivially reversible with a public decoder	**Low**
FTP service accepted weak, guessable-style credentials and allowed full download of sensitive files, including a hidden dotfile	**Medium**
Data hidden with Steghide used a weak, wordlist-crackable passphrase ("password"), broken instantly with StegSeek	**Medium**
A PNG's file signature was manually corrupted as an obscurity measure — trivial to detect and fix with a hex editor	**Informational**
SSH accepted a weak, dictionary password ("M3tahuman") that was brute-forceable with Hydra once usernames were known	**High**
Sudo/pkexec misconfiguration allowed the low-privileged user to spawn a root shell with no path or argument restriction (GTFOBins)	**Critical**

6. Conclusion

Lian_Yu was a well-rounded box combining web enumeration, encoding tricks, steganography, manual file-format repair, and a classic sudo/GTFOBins privilege escalation. The main takeaways were to always check hidden comments and directories on a web server, never trust encoding as security, and to keep sudo rules tightly scoped — pkexec with no path restriction was an instant path to root.